

Conclusions i propostes a futur

1. Conclusions

RedTrace ha estat un projecte que ha anat molt més enllà d'implementar algorismes de graf. El que ens ha obligat a fer és pensar un sistema complet: des de com modelar una xarxa real exportada per ShadowScan fins a com presentar els resultats d'una manera útil per a un analista de seguretat.

En l'aspecte tècnic, la decisió que més ens ha condicionat tot el projecte ha estat el disseny del TopologyGraph com a capa d'abstracció sobre NetworkX. Gràcies a aquesta encapsulació, tots els algorismes del motor accedeixen als nodes i arestes en $O(1)$ sense dependre de l'estructura interna de la llibreria. Ha estat una decisió correcta: quan vam haver de canviar com es calculaven els pesos, no vam tocar ni una sola línia dels algorismes.

El classificador ID3 ha demostrat ser molt més útil del que esperàvem. En lloc de codificar regles manuals del tipus 'si té el port 23 obert és CRITICAL', el model aprèn els patrons del dataset i generalitza. Amb només set features i dos-cents exemples, la classificació és prou fiable per als casos d'ús que plantegem.

L'anàlisi de complexitat ens ha donat una lliçó important sobre els algorismes de graf: la composició anidada no sempre implica $V \cdot V$. Quan recorrem els veïns de cada node en un bucle exterior de V iteracions, el cost real és E (la suma de tots els graus), no $V \cdot \text{deg_màx}$. Aquesta distinció és la que explica per què BFS és $\Theta(V+E)$ i no $O(V^2)$ en grafs esparsos com les xarxes corporatives típiques.

Finalment, el resultat més sorprenent de l'anàlisi de complexitat del pipeline ha estat que el coll d'ampolla no és cap dels algorismes de cerca, sinó el visualitzador de matplotlib, que és $O(V^2)$ pel spring_layout iteratiu. En xarxes grans, renderitzar el graf és més car que calcular el camí d'atac.

Resum dels aprenentatges principals:

Àrea	Aprenentatge clau
Disseny OOP	L'encapsulació a TopologyGraph va estalviar refactoritzacions costoses
Algorísmica	En grafs, $\sum \text{deg}(u) = E$ és el que permet reduir $O(V \cdot d)$ a $O(V+E)$
Machine Learning	Un arbre ID3 petit pot substituir regles manuals complexes
Complexitat	El bottleneck del pipeline és la visualització, no els algorismes
Integració	El pipeline ShadowScan → RedTrace valida el disseny modular

2. Propostes a futur

RedTrace és funcional, però hi ha tres línies clares d'evolució que ampliarien molt el seu abast:

2.1. Integració amb bases de dades CVE

Actualment, el pes d'explotació de cada aresta es calcula a partir dels ports oberts detectats per ShadowScan. Una millora directa seria connectar RedTrace a la base de dades CVE del NIST per enriquir cada node amb les vulnerabilitats conegudes dels seus serveis. Això faria que el pes reflectís el risc real d'explotació basat en CVSSv3, no una estimació basada en ports.

2.2. Suport per a xarxes IPv6 i topologies híbrides

El parser actual assumeix adreces IPv4. Amb l'adopció creixent d'IPv6 i la convivència de segments IPv4/IPv6 en xarxes corporatives modernes, caldria estendre el model de dades i el parser per gestionar les dues famílies d'adreces. A més, les topologies híbrides cloud/on-premise representen un cas d'ús real que RedTrace no cobreix.

2.3. Exposar RedTrace com a API REST

La GUI és útil per a demostracions, però en un entorn real d'auditoria el que interessa és integrar RedTrace amb altres eines. Exposar el motor com una API REST permetria que ShadowScan enviés el topology.json directament per HTTP i rebés l'informe en JSON sense cap intervenció manual. Eines com Metasploit o plataformes SIEM podrien consumir els resultats en temps real.

3. Reflexió final

Quan vam plantejar RedTrace, la pregunta era: donat un fitxer de topologia, quin camí seguiria un atacant? Ara, un cop acabat, la pregunta que RedTrace permet respondre és diferent i més útil: quins nodes cal blindar primer perquè l'atacant no pugui arribar a l'objectiu?

Aquesta diferència no és trivial. Passar de detectar vulnerabilitats puntuals a modelar moviment lateral és el que fa que RedTrace tingui valor real en un context de ciberseguretat ofensiva i defensiva. El projecte ens ha permès aplicar de forma conjunta teoria de grafs, POO, machine learning i anàlisi de complexitat en un sistema amb un cas d'ús concret i demostrable.

El codi és públic, documentat i estructurat per ser extensible. Qualsevol de les tres propostes de futur es pot implementar sense modificar el motor actual, que és exactament el que buscàvem amb el disseny Open/Closed.